

Gap Report Analysis



Prepared for:
Fullsoft, Inc.

March 16, 2025

Prepared by:
Sentinel Shield Security
Madeleine Greiner
Consultant

I.	Executive Summary.....	1
i.	Scope.....	1
II.	Framework Summary.....	1
III.	Gap Assessment Summary and Results.....	1
i.	Summary Status Table.....	1
ii.	Detailed Control Analysis.....	2
a.	AC-2: Account Management.....	2
b.	AC-3: Access Enforcement.....	2
c.	AC-7: Unsuccessful Logon Attempts.....	2
d.	AC-11: Session Lock.....	2
e.	AC-17: Remote Access.....	2
f.	AC-19: Access Control for Mobile Devices.....	2
g.	AC-20: Use of External Information Systems.....	2
h.	AU-2: Audit Events.....	3
i.	AU-6: Audit Review, Analysis, and Reporting.....	3
j.	CM-2: Baseline Configuration.....	3
k.	CM-6: Configuration Settings.....	3
l.	CM-7: Least Functionality.....	3
m.	CM-8: Information System Component Inventory.....	3
n.	IA-2: Identification and Authentication (Organizational Users).....	3
o.	IA-5: Authenticator Management.....	3
p.	IR-4: Incident Handling.....	4
q.	MA-4: Nonlocal Maintenance.....	4
r.	MP-5: Media Transport.....	4
s.	SC-7: Boundary Protection.....	4
t.	SC-8: Transmission Confidentiality and Integrity.....	4
u.	SC-13: Cryptographic Protection.....	4
v.	SC-28: Protection of Information at Rest.....	4
w.	SI-2: Flaw Remediation.....	4
x.	SI-3: Malicious Code Protection.....	4
y.	SI-4: Information System Monitoring.....	5

- iii. Nessus Scan Results Screenshots.....5
- IV. Overall Status.....6
 - i. Findings6
 - ii. Areas for Concern.....6
- V. Recommendations.....6
- VI. BYOD Policy.....6
- VII. Conclusion.....6

I. Executive Summary

This gap analysis report evaluates the discrepancies between the current state of Fullsoft, Inc.’s employee device setup on a BYOD policy and the NIST SP 800-53 Controls. The objective of this analysis is to identify and assess the gaps that exist and provide actionable recommendations for improvement. The current state of an employee’s device setup on Fullsoft, Inc.’s BYOD policy has a lack of requirement for signing for the remote SMB server as well as an untrusted SSL certificate. The recommendations to remove these gaps are to enforce message signing on the host’s configuration and to generate a proper SSL certificate for the device.

i. Scope

The scope of this gap analysis report is the entire network system for an employee’s personal device used with Fullsoft, Inc.’s BYOD policy.

II. Framework Summary

The NIST Cybersecurity Framework provides structured guidelines to assess and improve an organization’s security posture. It includes five core functions: Identify, Protect, Detect, Respond, and Recover. The assessment follows the controls outlined in NIST SP 800-53 and evaluated the adherence to these policies on a Fullsoft, Inc.’s employee’s personal device used in a BYOD policy.

III. Gap Assessment Summary and Results

This assessment took place between March 16, 2025, and March 21, 2025. There were 25 controls assessed through a Nessus Scan of a Fullsoft, Inc.’s employee’s home network system on a personal device.

i. Summary Status Table

Control Family	Status
Access Control	
Audit and Accountability	
Configuration Management	
Identification and Authentication	
Incident Response	
Maintenance	
Media Protection	
System and Communications Protection	
System and Information Integrity	

No controls met		Some controls met		All or nearly all controls met	
-----------------	--	-------------------	--	--------------------------------	--

ii. Detailed Control Analysis

a. AC-2: Account Management

The AC-2 control is fully compliant. The Nessus scan searched for user account issues such as inactive accounts, weak passwords, or improper account permissions. The scan found that there were no issues with any user accounts. Accounts were also cross-referenced with Common Platform Enumeration (CPE) to ensure accounts only had access to the authorized systems.

b. AC-3: Access Enforcement

AC-3: Access Enforcement is fully compliant. The SMB on the system assists in controlling who can access shared resources and files across the network. The WMI being blocked shows policy enforcement on the device and network. However, unauthorized SSH and DEC enumeration indicates improper access control settings.

c. AC-7: Unsuccessful Logon Attempts

The compliance to the control is unknown. There were no unsuccessful attempts that were detected on the network. However, there is no risk factor.

d. AC-11: Session Lock

The compliance to the control is unknown. There was no documentation in the scan regarding session lock. However, there is no risk factor.

e. AC-17: Remote Access

The compliance to the control is not met. AC-17 mandates secure remote access mechanisms, ensuring that authentication and encryption measures are in place to prevent unauthorized access. SMB Signing ensures integrity and authenticity of SMB communication, preventing man-in-the-middle attacks. If SMB Signing is not required, attackers can intercept and modify SMB traffic, violating the integrity requirements.

f. AC-19: Access Control for Mobile Devices

The AC-19 is fully compliant. The device type of the network the scan was conducted on is a general-purpose device with a confidence level of 50. Requiring encryption and strong authentication as well as limiting device to work-related use will help the device be more proper for a BYOD policy. However, there is no risk factor.

g. AC-20: Use of External Information Systems

The Use of External Information Systems access control is fully compliant. Remote operating systems were able to be accessed and determined by the Nessus scan using SSH or local commands. The confidence level is at 50, which presents some concerns, however, there is no risk factor.

h. AU-2: Audit Events

The AU-2: Audit Events control's compliance is fully met. Many aspects such as active connections, Netstat connection, and OS fingerprinting and identification are logged so that events can be audited

i. AU-6: Audit Review, Analysis, and Reporting

The compliance to the control is unknown. There was no documentation in the scan regarding how audits are reviewed, analyzed, or reported. However, there is no risk factor.

j. CM-2: Baseline Configuration

The compliance to the control is unknown. There were no baseline configurations that were documented. However, there is no risk factor.

k. CM-6: Configuration Settings

Most configuration settings are fully compliant. Only a few present potential issues such as SMB signing and SSH certificate. However, there is no risk factor seen in the Nessus scan.

l. CM-7: Least Functionality

The control of Least Functionality is fully compliant. Unnecessary services for SMB, HTTP, and service detection have been reduced or disabled to reduce attack surfaces on the system.

m. CM-8: Information System Component Inventory

Information System Component Inventory is fully compliant. All assets including devices, hardware and software, FQDNs, etc. are documented to accurately reflect the system without duplications.

n. IA-2: Identification and Authentication (Organizational Users)

The Identification and Authentication for Organizational Users is fully compliant. Authentication protocols are in place to identify organizational users and prevent any users that are not from the organization from accessing the network system.

o. IA-5: Authenticator Management

Authenticator Management controls are fully compliant. Authentication mechanisms such as passwords are implemented on the system to prevent unauthorized actors from accessing the data and system.

p. IR-4: Incident Handling

The compliance to the control is unknown. There was no incident response plan and no incident handling that was documented. However, there is no risk factor.

q. MA-4: Nonlocal Maintenance

The compliance to the control is unknown. There was no documentation of nonlocal maintenance done on the system. However, there is no risk factor.

r. MP-5: Media Transport

The compliance to the control is unknown. There was no transportation of media that was documented in the scan. However, there is no risk factor.

s. SC-7: Boundary Protection

The SC-7: Boundary Protection controls are fully compliant. SSL/TLS, web, and HTTP services all contribute to boundary protection. They help to prevent unauthorized access across

t. SC-8: Transmission Confidentiality and Integrity

Transmission Confidentiality and Integrity is fully compliant on the scanned system. The HTTP and SSL/TSL encryption provide both confidentiality and integrity of the data being transmitted.

u. SC-13: Cryptographic Protection

The SC-13 controls are not compliant. This control ensures proper cryptographic methods are used for secure communication. If an SSL certificate cannot be trusted, it may be self-

signed, expired, or issued by an untrusted Certificate Authority, making it vulnerable to man-in-the-middle (MITM) attacks and violating secure communication principles.

v. SC-28: Protection of Information at Rest

The protection of information at rest is currently not compliant. Certain security patches are not installed on the system, which could potentially put the information at rest on the system at risk. However, there is no risk at this time.

w. SI-2: Flaw Remediation

The SI-2: Flaw Remediation controls are currently fully compliant. Common Platform Enumeration (CPE) is currently being used to identify and manage vulnerabilities. This will assist in tracking and remediating these vulnerabilities.

x. SI-3: Malicious Code Protection

The compliance to the control is unknown. There were no documented protections against malicious code. However, there is no risk factor at this time.

y. SI-4: Information System Monitoring

Information System Monitoring controls are fully compliant. Information systems on the network are currently monitored through HTTP, TLS, port scanning, etc.

iii. Nessus Scan Results Screenshots

The first screenshot displays the 'HTTP Server Type and Version' scan results. The description states: 'This plugin attempts to determine the type and the version of the remote web server.' The output shows two results for the host 192.168.56.1:

Port	Hosts
16992 / tcp / www	192.168.56.1
623 / tcp / www	192.168.56.1

The second screenshot displays the 'Intel Management Engine Active Management Technology (AMT) Remote Access Enabled' scan results. The description states: 'The Intel Management Engine on the remote host has Active Management Technology (AMT) enabled, and is remotely accessible.' The output shows two results for the host 192.168.56.1:

Port	Hosts
623 / tcp / www	192.168.56.1
16992 / tcp / www	192.168.56.1

The image displays three screenshots of the Tenable Nessus Essentials interface, showing the results of a Gap Analysis Project Scan / Plugin #11011. The interface includes a sidebar with navigation options (Folders, Resources, Tenable News) and a main content area with tabs for Vulnerabilities, Info, Plugin Details, Risk Information, and Vulnerability Information.

Screenshot 1: Microsoft Windows SMB Service Detection

Vulnerabilities 24

INFO Microsoft Windows SMB Service Detection

Description
The remote service understands the CIFS (Common Internet File System) or Server Message Block (SMB) protocol, used to provide shared access to files, printers, etc between nodes on a network.

Output

An SMB server is running on this port.

To see debug logs, please visit individual host

Port	Hosts
139 / tcp / smb	192.168.56.1

A CIFS server is running on this port.

To see debug logs, please visit individual host

Port	Hosts
445 / tcp / cifs	192.168.56.1

Plugin Details

Severity: Info
ID: 11011
Version: 1.43
Type: remote
Family: Windows
Published: June 5, 2002
Modified: February 11, 2021

Risk Information

Risk Factor: None

Vulnerability Information

Asset inventory: True

Screenshot 2: Common Platform Enumeration (CPE)

Vulnerabilities 24

INFO Common Platform Enumeration (CPE)

Description
By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.
Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

See Also
<http://cpe.mitre.org/>
<https://nvd.nist.gov/products/cpe>

Output

The remote operating system matched the following CPE :

```
cpe:/o:microsoft:windows -> Microsoft Windows
```

Following application CPE matched on the remote system :

```
cpe:/a:tenable:nessus -> Tenable Nessus
```

Following hardware CPE matched on the remote system :

```
cpe:/h:intel:active_management_technology:11.8.97.4739 -> Intel Active Management Technology (AMT) Firmware
```

To see debug logs, please visit individual host

Port	Hosts
N/A	192.168.56.1

Plugin Details

Severity: Info
ID: 45590
Version: 1.179
Type: combined
Family: General
Published: April 21, 2010
Modified: March 13, 2025

Risk Information

Risk Factor: None

Screenshot 3: Device Type

Vulnerabilities 24

INFO Device Type

Description
Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

Output

Remote device type : general-purpose
Confidence level : 50

To see debug logs, please visit individual host

Port	Hosts
N/A	192.168.56.1

Plugin Details

Severity: Info
ID: 54615
Version: 1.3
Type: combined
Family: General
Published: May 23, 2011
Modified: March 12, 2025

Risk Information

Risk Factor: None

Prepared for Fullsoft, Inc. | NIST 800-53 Gap Analysis | March 16, 2025

Tenable

Nessus Essentials

Scans

Settings

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Terrascan

Tenable News

Google Cloud Platform (GCP)

Gemini Cloud Assist

Pr...

Read More

Gap Analysis Project Scan / Plugin #12053

[Back to Vulnerabilities](#)

Configure

Audit Trail

Launch

Report

Export

Vulnerabilities24

INFO

Host Fully Qualified Domain Name (FQDN) Resolution

<>

Plugin Details

Description

Nessus was able to resolve the fully qualified domain name (FQDN) of the remote host.

Output

192.168.56.1 resolves as DESKTOP-HFBOEAR.

To see debug logs, please visit individual host

Port	Hosts
N/A	192.168.56.1

Severity:Info

ID:12053

Version:1.17

Type:remote

Family:General

Published:February 11, 2004

Modified:March 13, 2025

Risk Information

Risk Factor: None

Tenable Nessus Essentials
Scans
Settings
mgreine3

FOLDERS

- My Scans
- All Scans
- Trash

RESOURCES

- Policies
- Plugin Rules
- Terrascan

Gap Analysis Project Scan / Plugin #42410

[Back to Vulnerabilities](#)

[Configure](#)
[Audit Trail](#)
[Launch](#)
[Report](#)
[Export](#)

Vulnerabilities 24

INFO

Microsoft Windows NTLMSSP Authentication Request Remote Network Name Disclosure

Description

The remote host listens on tcp port 445 and replies to SMB requests.

By sending an NTLMSSP authentication request it is possible to obtain the name of the remote system and the name of its domain.

Output

```
The following 2 NetBIOS names have been gathered :  
  
DESKTOP-HPB0EAR = Computer: name  
DESKTOP-HPB0EAR = Workgroup / Domain name
```

To see debug logs, please visit individual host

Port	Hosts
445 / tftp / cifs	192.168.56.1 🔗

Plugin Details

Severity: info
ID: 42410
Version: 1.7
Type: remote
Family: Windows
Published: November 6, 2009
Modified: November 22, 2019

Risk information

Risk Factor: None

Vulnerability Information

Asset Inventory: True

Tenable News

Google Cloud Platform (GCP)
Gemini Cloud Assistant... [Read More](#)

Tenable

Nessus Essentials
Scans
Settings

mgreine3

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Terrascan

Tenable News

Camaleon CMS

Privilege Escalation

Read More

INFO

Nessus Scan Information

Description

This plugin displays, for each tested host, information about the scan itself :

- The version of the plugin set.
- The type of scanner (Nessus or Nessus Home).
- The version of the Nessus Engine.
- The port scanner(s) used.
- The port range scanned.
- The ping round trip time
- Whether credentialed or third-party patch management checks are possible.
- Whether the display of superseded patches is enabled
- The date of the scan.
- The duration of the scan.
- The number of hosts scanned in parallel.
- The number of checks done in parallel.

Output

```

Information about this scan :

Nessus version : 10.8.3
Nessus build : 20010
Plugin feed version : 202503201709
Scanner edition used : Nessus Home
Scanner OS : WINDOWS
Scanner distribution : win-x86-64
...
More...

```

To see debug logs, please visit individual host

Port	Hosts
N/A	192.168.56.1

<

>

Plugin Details

Severity:

Info

ID:

19506

Version:

1.129

Type:

summary

Family:

Settings

Published:

August 26, 2005

Modified:

December 31, 2024

Risk Information

Risk Factor:

None

Tenable

Nessus Essentials

ScansSettings

3

mgreine3

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Terrascan

Tenable News

Granola API Endpoint Information Disclosure

Read More

Gap Analysis Project Scan / Plugin #64582

ConfigureAudit TrailLaunchReportExport

Vulnerabilities24

Back to Vulnerabilities

INFO

Netstat Connection Information

<>

Plugin Details

Description

The remote host has listening ports or established connections that Nessus was able to extract from the results of the 'netstat' command.

Note: The output for this plugin can be very long, and is not shown by default. To display it, enable verbose reporting in scan settings.

Output

top4 (listen)
szo: [host=0.0.0.0, port=135]
dat: [host=0.0.0.0, port=0]

top4 (listen)
szo: [host=0.0.0.0, port=445]
dat: [host=0.0.0.0, port=0]

To see debug logs, please visit individual host

Port

Hosts

N/A192.168.56.1

Severity:

Info

ID:

64582

Version:

1.13

Type:

local

Family:

General

Published:

February 13, 2013

Modified:

May 23, 2023

Risk Information

Risk Factor: None

Tenable

Nessus Essentials

ScansSettings

3

mgreine3

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Terrascan

Tenable News

Camaleon CMS Privilege Escalation

Read More

Gap Analysis Project Scan / Plugin #209654

ConfigureAudit TrailLaunchReportExport

Vulnerabilities24

Back to Vulnerabilities

INFO

OS Fingerprints Detected

<>

Plugin Details

Description

Using a combination of remote probes (TCP/IP, SMB, HTTP, NTP, SNMP, etc), it was possible to gather one or more fingerprints from the remote system. While the highest-confidence result was reported in plugin 11936, "OS Identification", the complete set of fingerprints detected are reported here.

Output

Following OS Fingerprints were found

Remote operating system : Windows
Confidence level : 50
Method : Misc
Type : general-purpose
Fingerprint : unknown

Following fingerprints could not be used to determine OS :
HTTP://Server: Intel(R) Active Management Technology 11.8.97.4739

SSLcert: //CN=Nessus Certification Authority/O=Nessus Users United/CN=DESKTOP-HPB0EARs/O=Nessus Users United/O=Nessus Server
3449d705797e35c5015b57df29f2be5aa6d453996

To see debug logs, please visit individual host

Port

Hosts

N/A192.168.56.1

Severity:

Info

ID:

209654

Version:

1.3

Type:

combined

Family:

General

Published:

February 26, 2025

Modified:

March 3, 2025

Risk Information

Risk Factor: None

Vulnerability Information

Asset Inventory: True

Tenable

Nessus Essentials

ScansSettings

3

mgreine3

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Terrascan

Gap Analysis Project Scan / Plugin #11936

ConfigureAudit TrailLaunchReportExport

Vulnerabilities24

Back to Vulnerabilities

INFO

OS Identification

<>

Plugin Details

Description

Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Output

Remote operating system : Windows
Confidence level : 50
Method : Misc

The remote host is running Windows

To see debug logs, please visit individual host

Port

Hosts

N/A192.168.56.1

Severity:

Info

ID:

11936

Version:

2.70

Type:

combined

Family:

General

Published:

December 9, 2003

Modified:

October 14, 2024

Risk Information

Risk Factor: None

Vulnerability Information

Asset Inventory: True

Nessus Essentials

Scans

Settings

2

🔔

mgreine3

FOLDERS

My Scans

All Scans

Trash

RESOURCES

🔗 Policies

🔗 Plugin Rules

🔗 Terrascan

Gap Analysis Project Scan / Plugin #97993

[Back to Vulnerabilities](#)

ConfigureAudit TrailLaunchReportExport

Vulnerabilities24

INFO

OS Identification and Installed Software Enumeration over SSH v2 (Using New SSH Library)

Description

Nessus was able to login to the remote host using SSH or local commands and extract the list of installed packages.

Output

Nessus can run commands on localhost to check if patches are applied.
Credentialed checks of Windows are not supported using SSH.

The remote host is not currently supported by this plugin.

Runtime : 1.71803 seconds

To see debug logs, please visit individual host

Port

Hosts

N/A192.168.56.1

Plugin Details

Severity:

Info

ID:

97993

Version:

1.57

Type:

remote

Family:

Misc.

Published:

May 30, 2017

Modified:

February 11, 2025

Risk Information

Risk Factor: None

Gap Analysis Project Scan / Plugin #21745

[Back to Vulnerabilities](#)

ConfigureAudit TrailLaunchReportExport

Vulnerabilities24

INFO

OS Security Patch Assessment Failed

Description

OS Security Patch Assessment is not available for this host because either the credentials supplied in the scan policy did not allow Nessus to log into it or some other problem occurred.

Solution

Fix the problem(s) so that OS Security Patch Assessment is possible.

Output

The following service errors were logged :

- Plugin : smb_login.nasl
Plugin ID : 10394
Plugin Name : Microsoft Windows SMB Log In Possible
Protocol : SMB
Message :
It was not possible to log into the remote host via smb (invalid credentials).

To see debug logs, please visit individual host

Port

Hosts

N/A192.168.56.1

Plugin Details

Severity:

Info

ID:

21745

Version:

1.32

Type:

remote

Family:

Settings

Published:

June 23, 2006

Modified:

July 12, 2021

Risk Information

Risk Factor: None

Reference Information

IAVB: 0001-B-0501

Gap Analysis Project Scan / Plugin #117886

[Back to Vulnerabilities](#)

ConfigureAudit TrailLaunchReportExport

Vulnerabilities24

INFO

OS Security Patch Assessment Not Available

Description

OS Security Patch Assessment is not available on the remote host.
This does not necessarily indicate a problem with the scan.
Credentials may not have been provided, OS security patch assessment may not be supported for the target, the target may not have been identified, or another issue may have occurred that prevented OS security patch assessment from being available. See plugin output for details.

This plugin reports non-failure information impacting the availability of OS Security Patch Assessment. Failure information is reported by plugin 21745 : OS Security Patch Assessment failed. If a target host is not supported for OS Security Patch Assessment, plugin 110695 : OS Security Patch Assessment Checks Not Supported will report concurrently with this plugin.

Output

The following issues were reported :

- Plugin : ssh_get_info2.nasl
Plugin ID : 97993
Plugin Name : OS Identification and Installed Software Enumeration over SSH v2 (Using New SSH Library)
Protocol : LOCALHOST
Message :
Credentialed checks of Windows are not supported using SSH.

To see debug logs, please visit individual host

Port

Hosts

N/A192.168.56.1

Plugin Details

Severity:

Info

ID:

117886

Version:

1.12

Type:

summary

Family:

Settings

Published:

October 2, 2018

Modified:

July 12, 2021

Risk Information

Risk Factor: None

Reference Information

IAVB: 0001-B-0515

Tenable News

Cybersecurity

Snapshot: Tenable

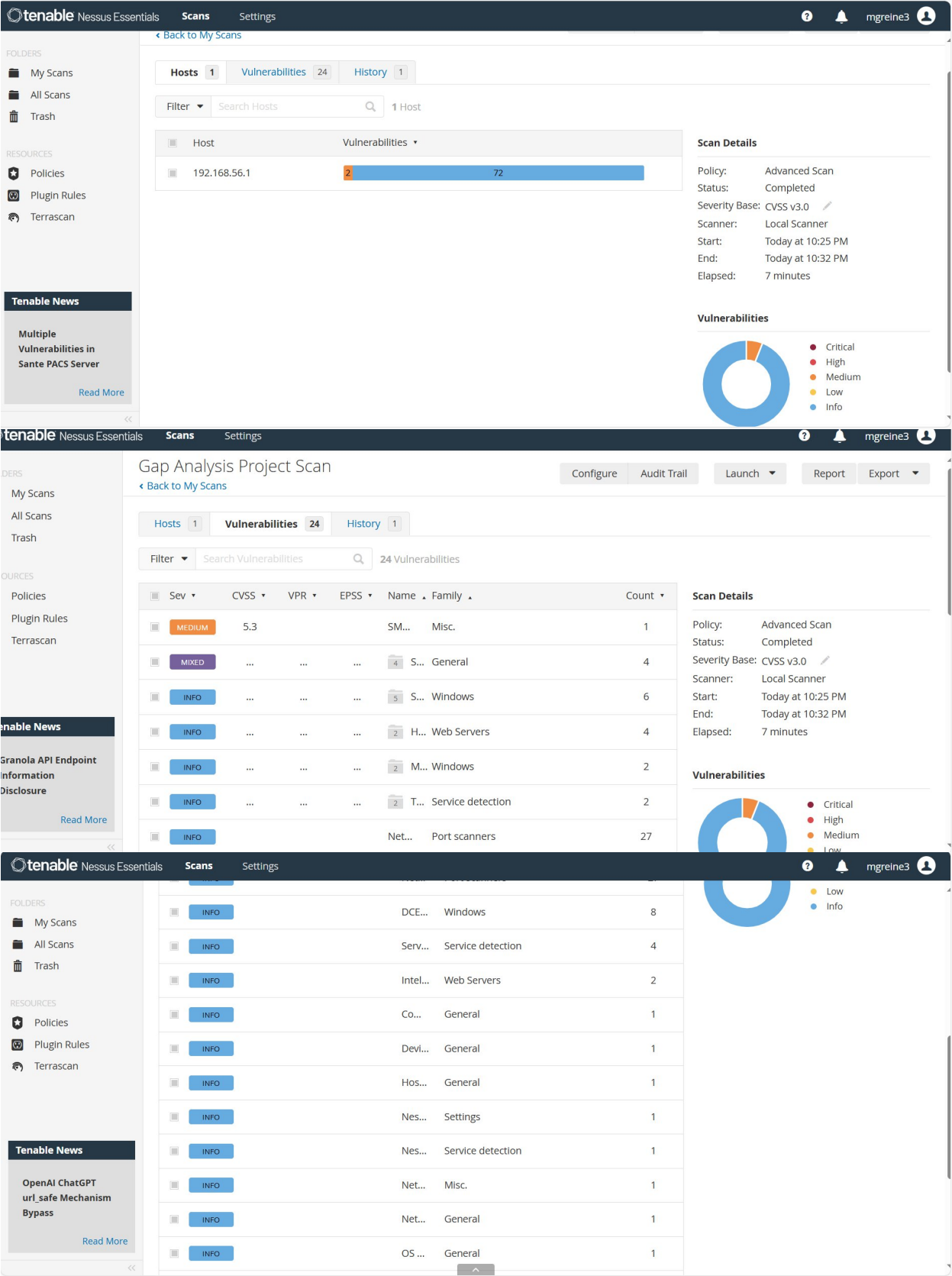
Highlights Risks o...

Choosing the Right

Cloud Security

Provider: Five N...

Read More



tenable

Nessus Essentials

Scans

Settings

?

🔔

mgreine3

👤

FOLDERS

My Scans

All Scans

Trash

RESOURCES

★ Policies

🔧 Plugin Rules

🔍 Terrascan

Tenable News

Camaleon CMS Privilege Escalation

Read More

INFO

SSL Perfect Forward Secrecy Cipher Suites Supported

<

Description

The remote host supports the use of SSL ciphers that offer Perfect Forward Secrecy (PFS) encryption. These cipher suites ensure that recorded SSL traffic cannot be broken at a future date if the server's private key is compromised.

See Also

<https://www.openssl.org/docs/manmaster/man1/ciphers.html>
https://en.wikipedia.org/wiki/Diffie-Hellman_key_exchange
https://en.wikipedia.org/wiki/Perfect_forward_secrecy

Output

Here is the list of SSL PFS ciphers supported by the remote server :

High Strength Ciphers (>= 112-bit key)

Name	Code	KEX	Auth	Encryption
-----	-----	---	---	-----
EPHHE_DHEA_1PFE178_CBA7EE	0x00000000	EPHHE	DHEA	1PFE178
more...				

To see debug logs, please visit individual host

Plugin Details

Severity: Info
ID: 57041
Version: 1.11
Type: remote
Family: General
Published: December 7, 2011
Modified: March 9, 2021

Risk Information

Risk Factor: None

tenable

Nessus Essentials

Scans

Settings

?

🔔

mgreine3

👤

FOLDERS

My Scans

All Scans

Trash

RESOURCES

★ Policies

🔧 Plugin Rules

🔍 Terrascan

Tenable News

DeepSeek Deep Dive Part 1: Creating Malware, Inclu...

Read More

INFO

Microsoft Windows SMB Service Detection

>

Description

The remote service understands the CIFS (Common Internet File System) or Server Message Block (SMB) protocol, used to provide shared access to files, printers, etc between nodes on a network.

Output

An SMB server is running on this port.

To see debug logs, please visit individual host

Port	Hosts
139 / tcp / smb	192.168.56.1

A CIFS server is running on this port.

To see debug logs, please visit individual host

Port	Hosts
445 / tcp / cifs	192.168.56.1

Plugin Details

Severity: Info
ID: 11011
Version: 1.43
Type: remote
Family: Windows
Published: June 5, 2002
Modified: February 11, 2021

Risk Information

Risk Factor: None

Vulnerability Information

Asset Inventory: True

tenable

Nessus Essentials

Scans

Settings

?

🔔

mgreine3

👤

Back to Vulnerability Group

Hosts 1

Vulnerabilities 24

History 1

INFO

Microsoft Windows SMB NativeLanManager Remote System Information Discl...

<

>

Description

Nessus was able to obtain the remote operating system name and version (Windows and/or Samba) by sending an authentication request to port 139 or 445. Note that this plugin requires SMB to be enabled on the host.

Output

Nessus was able to obtain the following information about the host, by parsing the SMB2 Protocol's NTLM SSP message:

Target Name: DESKTOP-HPB0EAR
NetBIOS Domain Name: DESKTOP-HPB0EAR
NetBIOS Computer Name: DESKTOP-HPB0EAR
DNS Domain Name: DESKTOP-HPB0EAR
DNS Computer Name: DESKTOP-HPB0EAR
DNS Tree Name: unknown
Product Version: 10.0.19041

To see debug logs, please visit individual host

Port	Hosts
445 / tcp / cifs	192.168.56.1

Plugin Details

Severity: Info
ID: 10785
Version: 1.54
Type: remote
Family: Windows
Published: October 17, 2001
Modified: September 20, 2021

Risk Information

Risk Factor: None

Vulnerability Information

Asset Inventory: True

Nessus Essentials

Scans

Settings

?

mgreine3

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Terrascan

Tenable News

Multiple Vulnerabilities in Sante PACS Server

Read More

Gap Analysis Project Scan / Plugin #100871

[Back to Vulnerability Group](#)

Configure

Audit Trail

Launch

Report

Export

Hosts 1

Vulnerabilities 24

History 1

INFO

Microsoft Windows SMB Versions Supported (remote check)

< >

Description

Nessus was able to obtain the version of SMB running on the remote host by sending an authentication request to port 139 or 445.

Note that this plugin is a remote check and does not work on agents.

Output

The remote host supports the following versions of SMB :
SMBv2

To see debug logs, please visit individual host

Port	Hosts
445 / tcp / cifs	192.168.56.1

Plugin Details

Severity: Info

ID: 100871

Version: 1.2

Type: remote

Family: Windows

Published: June 19, 2017

Modified: November 22, 2019

Risk Information

Risk Factor: None

Vulnerability Information

Asset Inventory: True

Nessus Essentials

Scans

Settings

?

mgreine3

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Terrascan

Tenable News

Granola API Endpoint Information Disclosure

Read More

Hosts 1

Vulnerabilities 24

History 1

INFO

Microsoft Windows SMB2 and SMB3 Dialects Supported (remote check)

< >

Description

Nessus was able to obtain the set of SMB2 and SMB3 dialects running on the remote host by sending an authentication request to port 139 or 445.

Output

The remote host supports the following SMB dialects :
version introduced in windows version_
2.0.2 Windows 2008
2.1 Windows 7
3.0 Windows 8
3.0.2 Windows 8.1
3.1.1 Windows 10

The remote host does NOT support the following SMB dialects :
version introduced in windows version_
2.2.2 Windows 8 Beta
2.2.4 Windows 8 Beta
3.1 Windows 10

To see debug logs, please visit individual host

Port	Hosts
445 / tcp / cifs	192.168.56.1

Plugin Details

Severity: Info

ID: 106716

Version: 1.6

Type: remote

Family: Windows

Published: February 9, 2018

Modified: March 11, 2020

Risk Information

Risk Factor: None

Vulnerability Information

Asset Inventory: True

Nessus Essentials

Scans

Settings

?

mgreine3

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Terrascan

Tenable News

Choosing the Right Cloud Security Provider: Five N...

Read More

Hosts 1

Vulnerabilities 24

History 1

INFO

Windows NetBIOS / SMB Remote Host Information Disclosure

<

Description

The remote host is listening on UDP port 137 or TCP port 445, and replies to NetBIOS nbtscan or SMB requests.

Note that this plugin gathers information to be used in other plugins, but does not itself generate a report.

Output

The following 2 NetBIOS names have been gathered :
DESKTOP-HPB0EAR = Computer name
DESKTOP-HPB0EAR = Workgroup / Domain name

To see debug logs, please visit individual host

Port	Hosts
445 / tcp / cifs	192.168.56.1

Plugin Details

Severity: Info

ID: 10150

Version: 1.91

Type: remote

Family: Windows

Published: October 12, 1999

Modified: February 10, 2021

Risk Information

Risk Factor: None

tenable

Nessus Essentials

Scans

Settings

?

🔔

mgreine3

Back to Vulnerability Group

Hosts1

Vulnerabilities24

History1

INFO

WMI Not Available

Description

WMI (Windows Management Instrumentation) is not available on the remote host over DCOM. WMI queries are used to gather information about the remote host, such as its current state, network interface configuration, etc.

Without this information Nessus may not be able to identify installed software or security vulnerabilities that exist on the remote host.

See Also

<https://docs.microsoft.com/en-us/windows/win32/wmisdk/wmi-start-page>

Output

Can't connect to the 'root\CIMV2' WMI namespace.

To see debug logs, please visit individual host

Port	Hosts
445 / tcp / cifs	192.168.56.1

Plugin Details

Severity:Info

ID:135860

Version:1.137

Type:local

Family:Windows

Published:April 21, 2020

Modified:March 11, 2025

Risk Information

Risk Factor:None

Vulnerability Information

CPE: cpe:/o:microsoft:windows

FOLDERS

My Scans

All Scans

Trash

RESOURCES

★ Policies

🔧 Plugin Rules

🔍 Terrascan

Tenable News

Camaleon CMS

Privilege Escalation

Read More

tenable

Nessus Essentials

Scans

Settings

?

🔔

mgreine3

Gap Analysis Project Scan / Plugin #136318

Configure

Audit Trail

Launch

Report

Export

Back to Vulnerability Group

Hosts1

Vulnerabilities24

History1

INFO

TLS Version 1.2 Protocol Detection

Description

The remote service accepts connections encrypted using TLS 1.2.

See Also

<https://tools.ietf.org/html/rfc5246>

Output

TLSv1.2 is enabled and the server supports at least one cipher.

To see debug logs, please visit individual host

Port	Hosts
8834 / tcp / www	192.168.56.1

Plugin Details

Severity:Info

ID:136318

Version:1.1

Type:remote

Family:Service detection

Published:May 4, 2020

Modified:May 4, 2020

Risk Information

Risk Factor:None

FOLDERS

My Scans

All Scans

Trash

RESOURCES

★ Policies

🔧 Plugin Rules

🔍 Terrascan

Tenable News

Cybersecurity

Snapshot: Tenable

Highlights Risks o...

Read More

tenable

Nessus Essentials

Scans

Settings

?

🔔

mgreine3

Gap Analysis Project Scan / Plugin #138330

Configure

Audit Trail

Launch

Report

Export

Back to Vulnerability Group

Hosts1

Vulnerabilities24

History1

INFO

TLS Version 1.3 Protocol Detection

Description

The remote service accepts connections encrypted using TLS 1.3.

See Also

<https://tools.ietf.org/html/rfc8446>

Output

TLSv1.3 is enabled and the server supports at least one cipher.

To see debug logs, please visit individual host

Port	Hosts
8834 / tcp / www	192.168.56.1

Plugin Details

Severity:Info

ID:138330

Version:1.2

Type:remote

Family:Service detection

Published:July 9, 2020

Modified:December 13, 2023

Risk Information

Risk Factor:None

FOLDERS

My Scans

All Scans

Trash

RESOURCES

★ Policies

🔧 Plugin Rules

🔍 Terrascan

Tenable News

Cybersecurity

Snapshot: Tenable

Highlights Risks o...

Read More

The image displays three screenshots of the Tenable Nessus Essentials interface, showing vulnerability scan results for different plugins. Each screenshot includes a sidebar with navigation options (Folders, Resources, Tenable News) and a main content area with details for a specific vulnerability.

Screenshot 1: Netstat Portscanner (SSH)

Hosts: 1 | **Vulnerabilities:** 24 | **History:** 1

INFO Netstat Portscanner (SSH)

Description
Nessus was able to run 'netstat' on the remote host to enumerate the open ports. If 'netstat' is not available, the plugin will attempt to use 'ss'.
See the section 'plugins options' about configuring this plugin.
Note: This plugin will run on Windows (using netstat.exe) in the event that the target being scanned is localhost.

See Also
<https://en.wikipedia.org/wiki/Netstat>

Output
Port 135/tcp was found to be open
To see debug logs, please visit individual host

Port	Hosts
135 / tcp / epmap	192.168.56.1

Plugin Details
Severity: Info
ID: 14272
Version: 1.109
Type: local
Family: Port scanners
Published: August 15, 2004
Modified: February 19, 2025
Risk Information
Risk Factor: None

Screenshot 2: DCE Services Enumeration

Hosts: 1 | **Vulnerabilities:** 24 | **History:** 1

INFO DCE Services Enumeration

Description
By sending a Lookup request to the portmapper (TCP 135 or epmapper PIPE) it was possible to enumerate the Distributed Computing Environment (DCE) services running on the remote port. Using this information it is possible to connect and bind to each service by sending an RPC request to the remote port/pipe.

Output
The following DCE RPC services are available locally :
Object UUID : 00000000-0000-0000-0000-000000000000
UUID : 51a227ae-825b-41f2-b4a9-1ac9557a1018, version 1.0
Description : Unknown RPC service
Annotation : Ngc Pop Key Service
Type : Local RPC service
Named pipe : samss ipc
more...

To see debug logs, please visit individual host

Port	Hosts
135 / tcp / epmap	192.168.56.1

Plugin Details
Severity: Info
ID: 10736
Version: 1.57
Type: combined
Family: Windows
Published: August 26, 2001
Modified: October 4, 2021
Risk Information
Risk Factor: None
Vulnerability Information
Asset Inventory: True

Screenshot 3: Service Detection

Hosts: 1 | **Vulnerabilities:** 24 | **History:** 1

INFO Service Detection

Description
Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

Output
A web server is running on this port.
To see debug logs, please visit individual host

Port	Hosts
16992 / tcp / www	192.168.56.1
623 / tcp / www	192.168.56.1

A web server is running on this port through TLSv1.2.
To see debug logs, please visit individual host

Port	Hosts
8834 / tcp / www	192.168.56.1

Plugin Details
Severity: Info
ID: 22964
Version: 1.194
Type: remote
Family: Service detection
Published: August 19, 2007
Modified: March 26, 2024
Risk Information
Risk Factor: None

IV. Overall Status

i. Findings

The findings from the gap analysis assessment show that a large majority of the access controls have full compliance. There are some controls that have unknown compliance statuses and there are a few controls (AC-17, SC-13, and SC-28) that are not met.

ii. Areas for Concern

One concern is the lack of compliance with AC-17 in regard to the SMB signature not being required. Another concern is the untrusted SSL certificate that causes compliance to not be met on SC-13. Both present concerns for potential man-in-the-middle attacks. Another concern is the lack of compliance in SC-28 and there not being patches installed to protect data at rest.

V. Recommendations

It is recommended that Fullsoft, Inc.'s employees should update their network systems to require messages to be signed on the hosts configuration. Additionally, all employees should generate proper SSL certificates for their devices. These recommendations will help to prevent man-in-the-middle attacks. It is also recommended that all employees install all necessary security patches to protect information at rest. Controls that have unclear compliancy should be looked at further to determine their compliancy status.

VI. BYOD Policy

The gaps provided in the assessment could put the company at risk if a BYOD policy is applied. The current state of the network not requiring SMB signatures and having untrusted an SSL certificate puts the company at risk for being subject to many man-in-the-middle attacks. Additionally, the network does not have patches installed to help protect the company's data when it is at rest. The recommendations provided could help to make employees' networks more secure so that a BYOD policy would not put the company's assets at risk.

VII. Conclusion

The Gap Analysis Assessment of Fullsoft, Inc. has identified key areas where cybersecurity controls align with the NIST Cybersecurity Framework, as well as areas requiring improvement. While several controls are effectively implemented, certain vulnerabilities, such as SMB Signing not being required, untrusted SSL certificates, and lack of vulnerability patches, present risks that need to be addressed. To enhance security, the organization should focus on requiring SMB

signing, as well as updating the system to include necessary vulnerability patches. Trustworthy SSL certificates should also be acquired. Moving forward, continuous monitoring, regular security assessments, and employee training will be critical in maintaining compliance and proactively mitigating threats. By addressing these gaps, Fullsoft, Inc. will be well-positioned to enhance its security posture and protect its assets against evolving cyber threats.

References

- CSF Tools. (2021, March 5). *Access Control - CSF tools*. CSF Tools - the Cybersecurity Framework for Humans. <https://csf.tools/reference/nist-sp-800-53/r5/ac/>
- CSF Tools. (2024a, December 6). *Audit and Accountability - CSF tools*. CSF Tools - the Cybersecurity Framework for Humans. <https://csf.tools/reference/nist-sp-800-53/r5/au/>
- CSF Tools. (2024b, December 6). *Configuration Management - CSF Tools*. CSF Tools - the Cybersecurity Framework for Humans. <https://csf.tools/reference/nist-sp-800-53/r5/cm/>
- CSF Tools. (2024c, December 6). *Incident response - CSF tools*. CSF Tools - the Cybersecurity Framework for Humans. <https://csf.tools/reference/nist-sp-800-53/r5/ir/>
- CSF Tools. (2024d, December 6). *Maintenance - CSF tools*. CSF Tools - the Cybersecurity Framework for Humans. <https://csf.tools/reference/nist-sp-800-53/r5/ma/>
- CSF Tools. (2024e, December 6). *Media Protection - CSF tools*. CSF Tools - the Cybersecurity Framework for Humans. <https://csf.tools/reference/nist-sp-800-53/r5/mp/>
- CSF Tools. (2024f, December 6). *System and Communications Protection - CSF tools*. CSF Tools - the Cybersecurity Framework for Humans. <https://csf.tools/reference/nist-sp-800-53/r5/sc/>
- CSF Tools. (2024g, December 6). *System and Information Integrity - CSF tools*. CSF Tools - the Cybersecurity Framework for Humans. <https://csf.tools/reference/nist-sp-800-53/r5/si/>
- OpenAI. (2025). ChatGPT (Mar 16 version) [Large language model]. <https://chat.openai.com/c/67db48b2-4d4c-800f-8147-dbd22069614b>
- OpenAI. (2025). ChatGPT (Mar 16 version) [Large language model]. <https://chat.openai.com/c/67e049b5-9324-800f-a23e-5c62a03e0fc9>